

Lab: Authentication bypass via OAuth implicit flow

1. Mục đích của bài lab

- Mục tiêu là chứng minh rằng ứng dụng web không kiểm tra đầy đủ thông tin người dùng nhận được từ OAuth Provider, dẫn đến việc kẻ tấn công có thể giả mạo danh tính của người dùng khác và đăng nhập vào tài khoản của họ mà không cần biết mật khẩu.

2. Trả lời câu hỏi

1. OAuth là gì và nó hỗ trợ phân quyền như thế nào?

-OAuth (Open Authorization) là một giao thức ủy quyền cho phép các ứng dụng bên thứ ba truy cập vào tài nguyên của người dùng mà không cần biết mật khẩu của họ. Thay vì chia sẻ thông tin đăng nhập, người dùng xác thực trực tiếp với nhà cung cấp dịch vụ như Google hoặc Microsoft và cấp quyền cho ứng dụng truy cập một số dữ liệu hoặc chức năng nhất định. Sau khi được cấp quyền, ứng dụng sẽ nhận được một Access Token để truy cập các tài nguyên được cho phép. Nhờ đó, OAuth giúp tăng cường bảo mật, giảm nguy cơ lộ mật khẩu và cung cấp cơ chế phân quyền linh hoạt trong các ứng dụng web hiện đại.

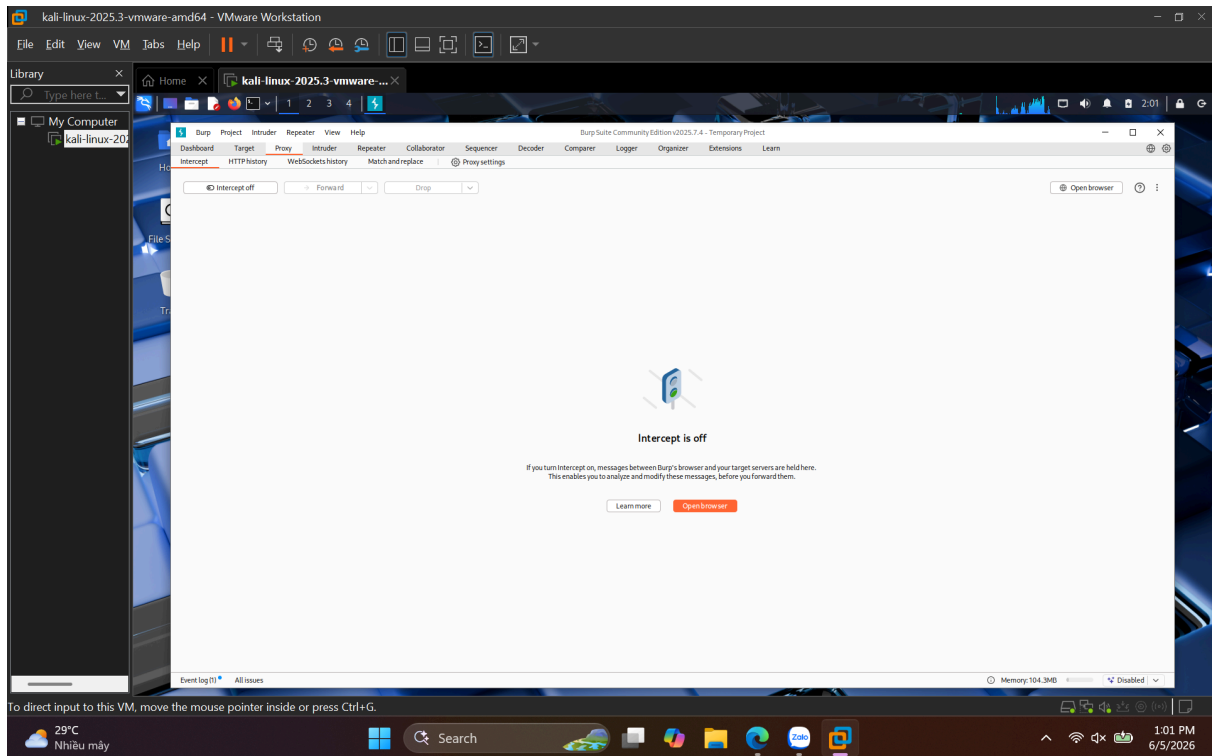
2. Consent Phishing trong OAuth được thực hiện như thế nào? Làm sao để phát hiện và phòng chống?

-Consent Phishing là một hình thức tấn công trong đó kẻ tấn công tạo ra một ứng dụng OAuth giả mạo và lừa người dùng cấp quyền truy cập vào tài khoản của họ. Kẻ tấn công thường gửi cho nạn nhân một liên kết đăng nhập hoặc yêu cầu cấp quyền cho một ứng dụng có vẻ hợp pháp. Khi người dùng đồng ý cấp quyền, ứng dụng độc hại sẽ nhận được Access Token và có thể truy cập các dữ liệu mà người dùng đã cho phép, chẳng hạn như email, danh bạ, tệp tin hoặc lịch làm việc, mà không cần biết mật khẩu của nạn nhân.

-Để phát hiện và ngăn chặn Consent Phishing, cần thường xuyên giám sát các ứng dụng OAuth được cấp quyền, kiểm tra các quyền truy cập bất thường và theo dõi các hoạt động đáng ngờ liên quan đến Access Token. Ngoài ra, người dùng chỉ nên cấp quyền cho các ứng dụng đáng tin cậy, áp dụng nguyên tắc Least Privilege (chỉ cấp các quyền thực sự cần thiết), sử dụng danh sách ứng dụng được phê duyệt và thường xuyên rà soát, thu hồi các quyền không còn cần thiết. Những biện pháp này giúp giảm nguy cơ bị lạm dụng quyền OAuth và bảo vệ dữ liệu người dùng tốt hơn.

3. Chi tiết bài lab

B1. Khởi động Burp trên Kali

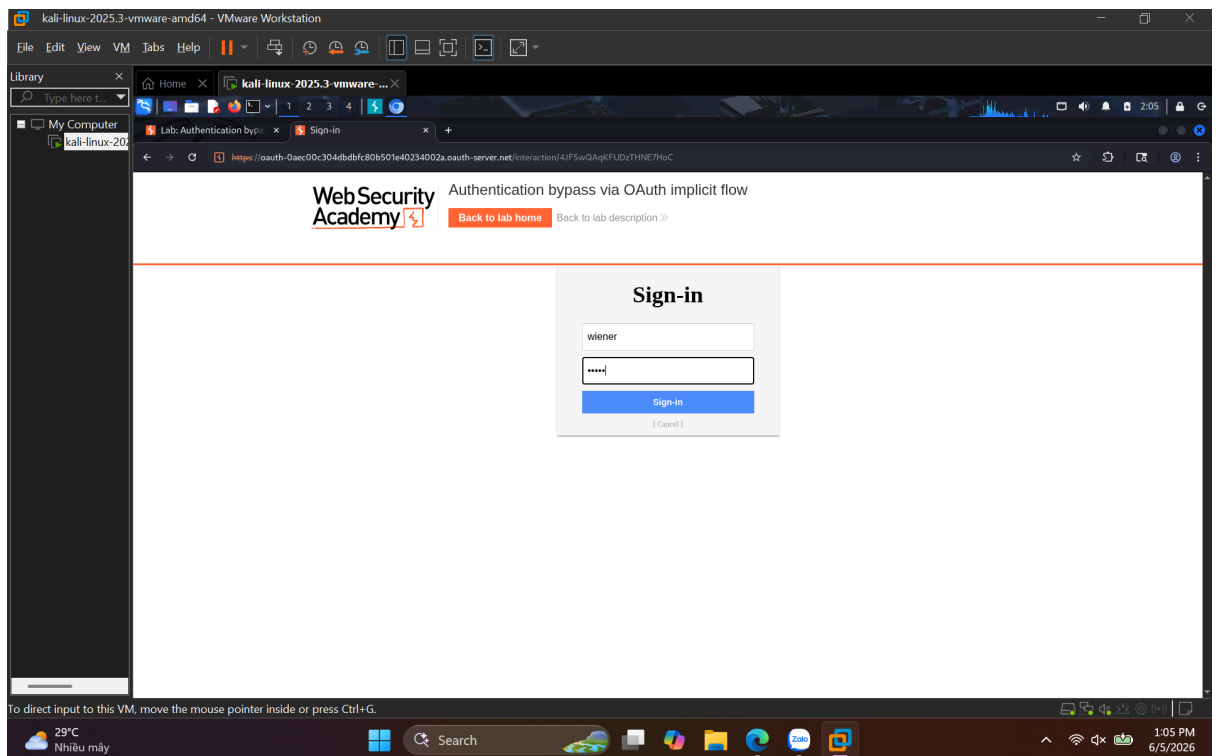


B2. Đăng nhập với tk và mk được cấp

User: wiener

Password: peter

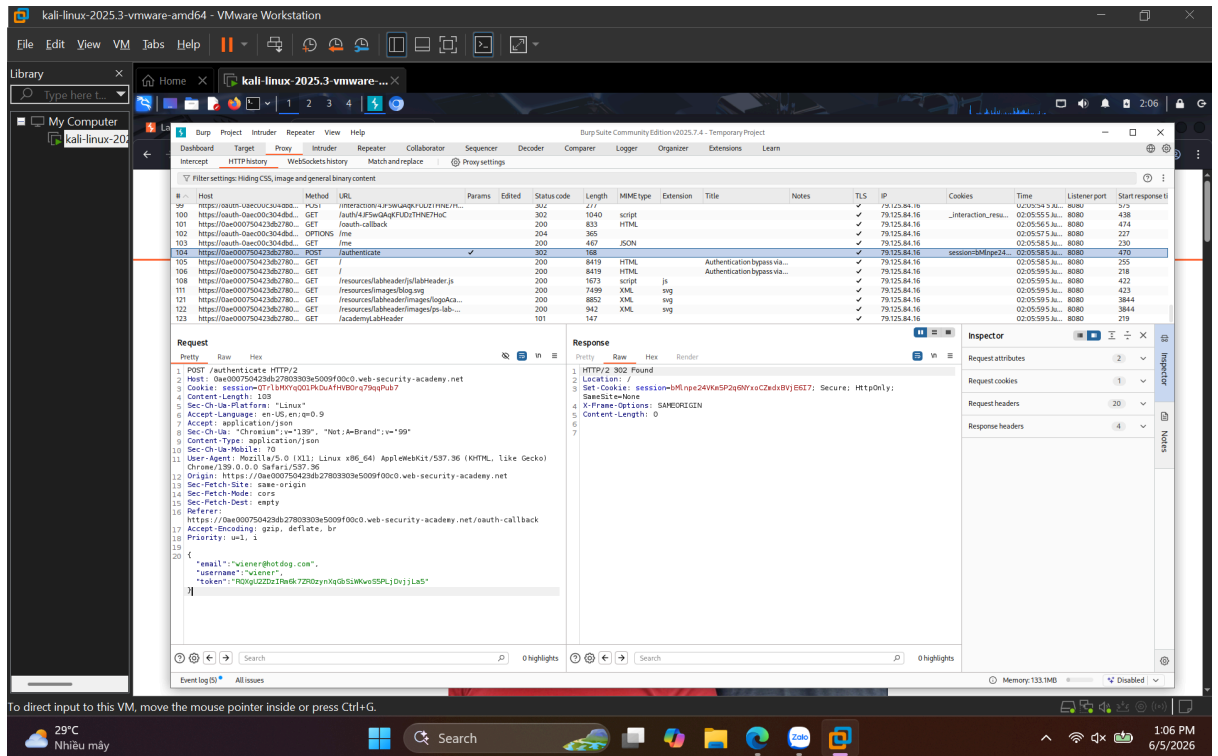
Sau đó ấn Continue



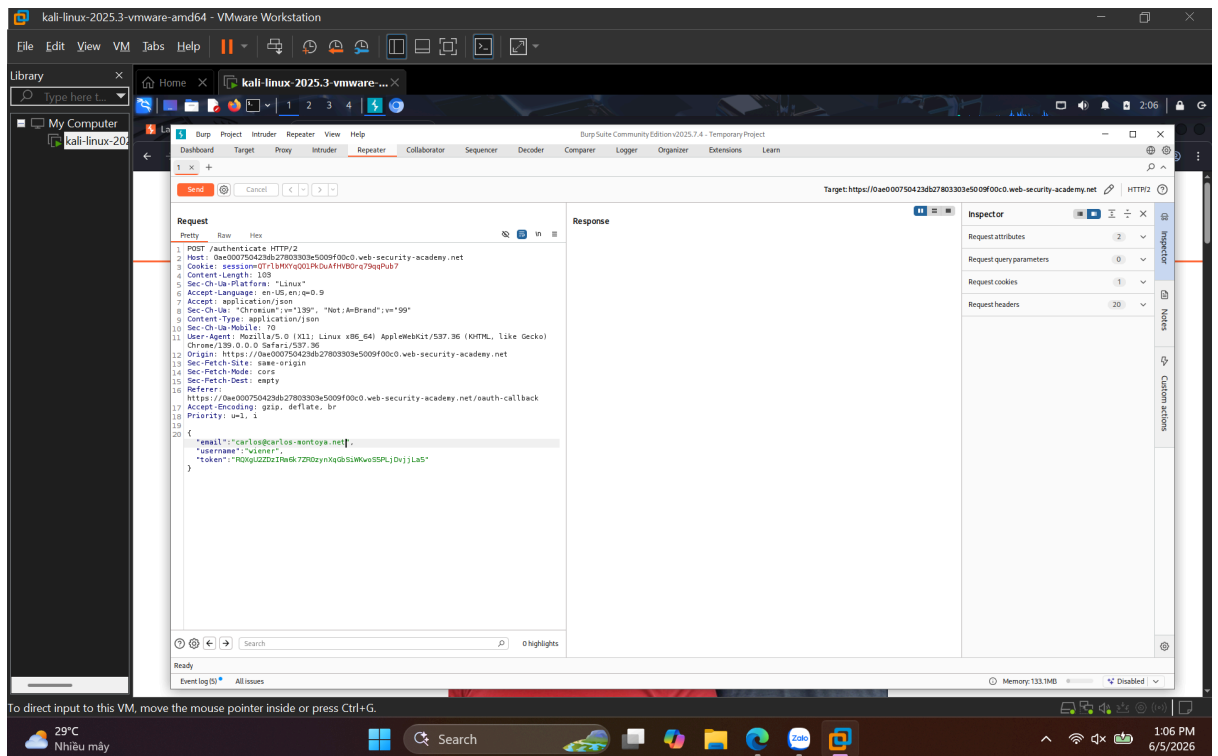
B3. Quan sát OAuth Flow trong Burp Suite

Tìm các request liên quan đến OAuth.

POST /authenticate

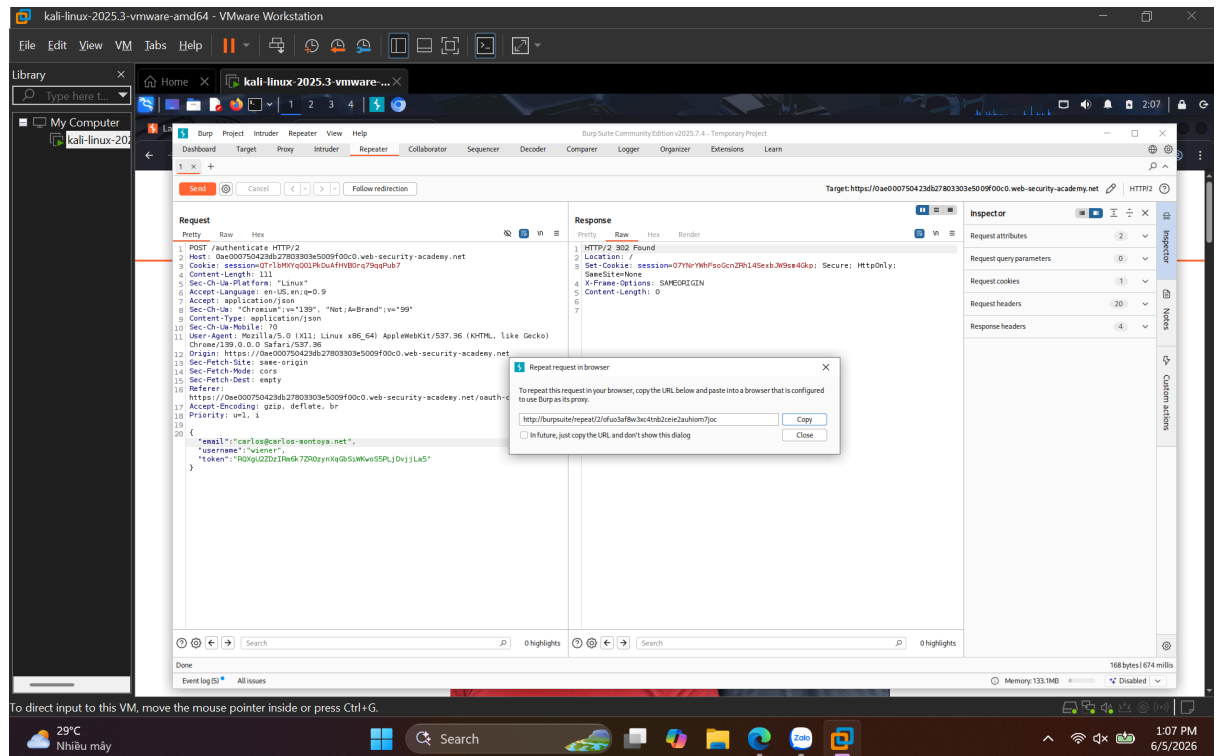


B4. Gửi request sang Repeater
Trong Repeater, sửa:
"email": "wiener@..."
"email": "carlos@carlos-montoya.net"



B5. Sau khi send, Trong Repeater:
→ Request in Browser

→ In Original Session
Burp sẽ tạo một URL đặc biệt



B7. Copy và truy cập vào URL vừa lấy được là hoàn thành

